Detection Engineering

(in Microsoft Sentinel and Defender XDR)

```
+=====================================+
| |         _)                        |
| | /  _ \  | \ \ / |  | (_-<  -_)  _||
|_\_\ \___/ _| \_/ \_,_| ___/ \___| \_||
+=====================================+
```

MSUG 26.11. 2024

On the menu today: Detection Engineering

- What are detections, what is detection engineering?
- A look at both the technical side and the workflow side.
- Selected indicators for good quality detections.
- DIY versus external detections.
- Microsoft Sentinel ja Defender XDR.

mikko@koivusec.fi

Hello, who’s this?

What do I do?

- I work as a self-employed security consultant.
- Clients include inhouse security teams and SOC service providers.
- Websites: koivusec.fi & secopslab.substack.com.

How I got started in security?

- BBS scene in the ‘90s introduced me to things like Phrack, 2600…
- After school went to work in IT: helpdesk -> infrastructure -> security.

Definitions

- A **detection** is a piece of logic inside a monitoring tool (often SIEM or EDR) to identify a specific activity based on logs, telemetry, behaviour or events.
- **Detection engineering** is the systematic approach to creating, deploying and refining these detections, to identify and respond to threats not already covered by existing security tooling.

… In Microsoft-land, we have multiple services that can provide detections, but most are today under XDR & Sentinel umbrella …

Who’s it for?

- Detection engineering is a **human-centric** activity.
- Requires a team with deep understanding of data, threat landscape, users, business services, IT architecture and security controls.
- Maturity jump from just consuming tools and vendor content.
- At the heart of a **modern SOC:**
  “hands on keyboards” instead of “eyes on glass”.

Benefits

- Reduced mean time to detect (MTTD).
- Increased awareness of both external and internal threats.
- Forces our focus to threat-informed defense.
- Coverage and confidence.
- Increased trust both in the team and the toolkit.
- Measurement and reporting.

mikko@koivusec.fi

Requirements

- Inputs: threat profiling, security testing, past incidens etc.
- Evidence: know what malicious activities look like.
- Data: SIEM, XDR, OS and app logs, network data…
  - Entra ID logs
  - Microsoft 365 logs
  - Azure Activity & Azure Diagnostics
  - Advanced Hunting data
  - SecurityEvents, Syslog/CEF, …

mikko@koivusec.fi

Indicators for high quality detections

1. Low false positives
    - Are the false alerts low / rare enough so the team is not overwhelmed?
2. True positives validated
    - Is the detection properly tested to ensure it works in real cases?
3. Robustness
    - Does the detection fire on all possible variations of an activity?
4. Documentation
    - Are external resources referenced: threat intelligence, blogs, tweets?
    - Are potential false positives identified?
    - Do we have investigation notes & a response playbook?
    - Is the detection mapped to MITRE ATT&CK techniques?

mikko@koivusec.fi

Detection as Code

- To do Detection Engineering at scale, modern software engineering practices are needed.
- Detections are managed as code in repositories and deployed with automated pipelines.
- Examples how certain products support Detection as Code:

Microsoft Sentinel	Defender XDR
Native API. Built-in deployment feature from Azure DevOps and GitHub.	Native API (Graph). No built-in deployment feature.
Detections written as ARM templates and KQL queries.	Detections written as JSON and KQL queries.

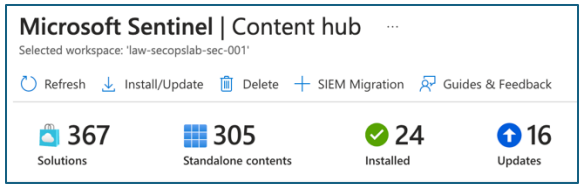
mikko@koivusec.fi

Azure-Sentinel / Solutions / Amazon Web Services / Analytic Rules / **AWS_S3BucketExposedviaACL.yaml**

ashwin-patil account entity fixes part3

Code | Blame | 48 lines (48 loc) · 2.04 KB

```yaml
id: 6b9b4ee6-f4c1-4b86-8c8c-beb0bb59ae44
name: S3 bucket exposed via ACL
description: |
  'Detected S3 bucket publicly exposed via ACL, which could lead for sensitive information leakage
severity: Medium
status: Available
requiredDataConnectors:
  - connectorId: AWS
    dataTypes:
      - AWSCloudTrail
queryFrequency: 1h
queryPeriod: 1h
triggerOperator: gt
triggerThreshold: 0
tactics:
  - Exfiltration
relevantTechniques:
  - T1537
query: |
  AWSCloudTrail
  | where EventName == "PutBucketAcl" and isempty(ErrorCode) and isempty(ErrorMessage)
  | extend UserIdentityArn = iif(isempty(UserIdentityArn), tostring(parse_json(Resources)[0].ARN),
  | extend UserName = tostring(split(UserIdentityArn, '/')[-1])
  | extend AccountName = case( UserIdentityPrincipalid == "Anonymous", "Anonymous", isempty(UserIde
  | extend AccountName = iif(AccountName contains "@", tostring(split(AccountName, '@', 0)[0]), Acc
    AccountUPNSuffix = iif(AccountName contains "@", tostring(split(AccountName, '@', 1)[0]), "")
  | extend Grant = parse_json(tostring((parse_json(RequestParameters).AccessControlPolicy))).Access
  | mvexpand Grant
  | extend cannedacl = parse_json(tostring((parse_json(RequestParameters))))
  | extend URI = parse_json(Grant).Grantee.URI, type = parse_json(Grant).Grantee.["xsi:type"], xamz
  | where (type == "Group" and (URI endswith "AllUsers" or URI endswith "AuthenticatedUsers"))
    or xamzacl in ("authenticated-read","public-read","public-read-write")
  | extend timestamp = TimeGenerated
entityMappings:
  - entityType: Account
    fieldMappings:
      - identifier: Name
        columnName: AccountName
      - identifier: UPNSuffix
        columnName: AccountUPNSuffix
      - identifier: CloudAppAccountId
        columnName: RecipientAccountId
  - entityType: IP
    fieldMappings:
      - identifier: Address
        columnName: SourceIpAddress
version: 1.0.1
kind: Scheduled
```



AWS-012 - S3 bucket exposed via ACL.json

Contents | History | Compare | Blame

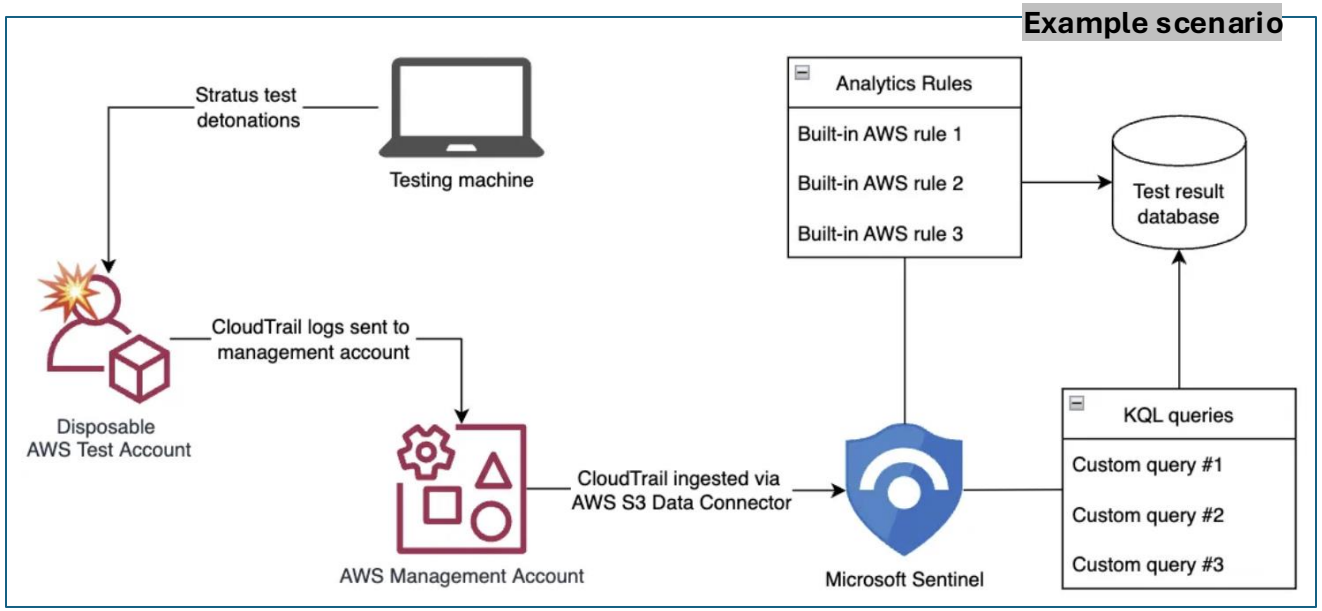
```json
{
    "$schema": "https://schema.management.azure.com/schemas/2019-04-01/deploymentTemplate.json#",
    "contentVersion": "1.0.0.0",
    "parameters": {
        "workspace": {
            "type": "String"
        }
    },
    "resources": [
        {
            "id": "[concat(resourceId('Microsoft.OperationalInsights/workspaces/providers', parameters('workspace'), 'Microsoft.SecurityInsights'),'/alertRules/
            "name": "[concat(parameters('workspace'),'/Microsoft.SecurityInsights/200593c0-1c76-47e7-80a6-a66a0ca35d13')]",
            "type": "Microsoft.OperationalInsights/workspaces/providers/alertRules",
            "kind": "Scheduled",
            "apiVersion": "2023-12-01-preview",
            "properties": {
                "displayName": "AWS-012 - S3 bucket exposed via ACL",
                "description": "Detected S3 bucket publicly exposed via ACL, which could lead for sensitive information leakage to the public. Verify the S3 obj
                "severity": "Medium",
                "enabled": true,
                "query": "AWSCloudTrail\n| where EventName == \"PutBucketAcl\" and isempty(ErrorCode) and isempty(ErrorMessage)\n| extend UserIdentityArn = iif(
                "queryFrequency": "PT1H",
                "queryPeriod": "PT1H",
                "triggerOperator": "GreaterThan",
                "triggerThreshold": 0,
                "suppressionDuration": "PT1H",
                "suppressionEnabled": false,
                "startTimeUtc": null,
                "tactics": [
                    "Exfiltration"
                ],
                "techniques": [
                    "T1537"
                ],
                "subTechniques": [],
                "alertRuleTemplateName": "6b9b4ee6-f4c1-4b86-8c8c-beb0bb59ae44",
                "incidentConfiguration": {
                    "createIncident": true,
                    "groupingConfiguration": {
                        "enabled": false,
                        "reopenClosedIncident": false,
                        "lookbackDuration": "PT5H",
                        "matchingMethod": "AllEntities",
                        "groupByEntities": [],
                        "groupByAlertDetails": [],
                        "groupByCustomDetails": []
                    }
                },
                "eventGroupingSettings": {
                    "aggregationKind": "SingleAlert"
                },
                "alertDetailsOverride": null,
                "customDetails": null,
                "entityMappings": [
                    {
                        "entityType": "Account",
                        "fieldMappings": [
                            {
                                "identifier": "Name",
                                "columnName": "AccountName"
                            },
                            {
                                "identifier": "UPNSuffix",
                                "columnName": "AccountUPNSuffix"
                            },
                            {
                                "identifier": "CloudAppAccountId",
                                "columnName": "RecipientAccountId"
                            }
                        ]
                    },
                    {
                        "entityType": "IP",
```

mikko@koivusec.fi

Detection testing

- **“Unit testing”**: verify that an individual use case is operating optimally, focusing on a single Analytics Rule or a small selection of related rules.
- **“Integration testing”**: validate that integrations are receiving data, data is healthy, and transformations and enrichments are working.
- **“End-to-end testing”**: verify functionality of all detections, automations and response actions related to a large system.
- Purple teaming!

Example scenario



"End-to-end testing"

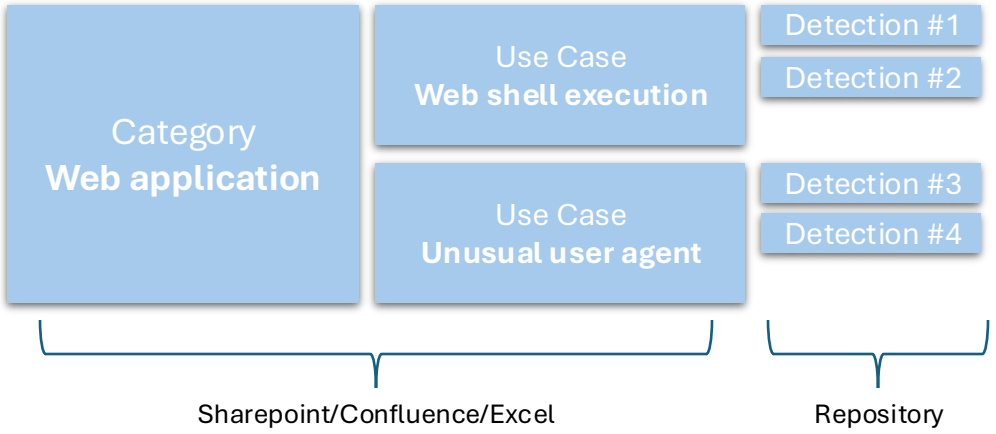
Medium	IN USE	Malformed user agent	Scheduled
Medium	IN USE	Full Admin policy created and then attached to Roles, Users or ...	Scheduled
Medium	IN USE	Exchange Server Vulnerabilities Disclosed March 2021 IoC Match	Scheduled
Medium	IN USE	AWS Guard Duty Alert	Scheduled
Medium	IN USE	(Preview) TI map IP entity to Network Session Events (ASIM Net...	Scheduled
Low	IN USE	Changes to AWS Security Group ingress and egress settings	Scheduled
Low	IN USE	Changes to Amazon VPC settings	Scheduled
Low	IN USE	Changes to internet facing AWS RDS Database instances	Scheduled
Low	IN USE	Changes to AWS Elastic Load Balancer security groups	Scheduled
Low	IN USE	New UserAgent observed in last 24 hours	Scheduled
Low	IN USE	NRT Login to AWS Management Console without MFA	NRT
Low	IN USE	Changes made to AWS CloudTrail logs	Scheduled
Low	IN USE	Login to AWS Management Console without MFA	Scheduled
Low	IN USE	Monitor AWS Credential abuse or hijacking	Scheduled

Detections

ID	Status	Stratus test scenario	Sentinel detection status	Log analytics data	Stratus ATT&CK mapping	Sentinel ATT&CK mapping	Notes
#1	Finished	Retrieve EC2 Password Data	No detection	Events found	Credential Access	-	
#2	Finished	Steal EC2 Instance Credentials	No detection	Events found	Credential Access	-	
#3	Finished	Retrieve a High Number of Secrets Manager secrets	No detection	Events found	Credential Access	-	
#4	Finished	Retrieve And Decrypt SSM Parameters	No detection	Events found	Credential Access	-	
#5	Finished	Delete CloudTrail Trail	Detected with rule "Changes made to AWS CloudTrail logs"	Events found	Defense Evasion	Defense Evasion	
#6	Finished	Disable CloudTrail Logging Through Event Selectors	No detection	Events found	Defense Evasion	-	PutEventSelectors event should be added in rule "Changes made to AWS CloudTrail logs".
#7	Finished	CloudTrail Logs Impairment Through S3 Lifecycle Rule	No detection	Events found	Defense Evasion	-	
#8	Finished	Stop CloudTrail Trail	Detected with rule "Changes made to AWS CloudTrail logs"	Events found	Defense Evasion	Defense Evasion	
#9	Finished	Attempt to Leave the AWS Organization	No detection	Events found	Defense Evasion	-	
#10	Finished	Remove VPC Flow Logs	Detected with rule "Changes made to AWS CloudTrail logs"	Events found	Defense Evasion	Defense Evasion	Should be detected with rule "Changes made to Amazon VPC settings".

Results

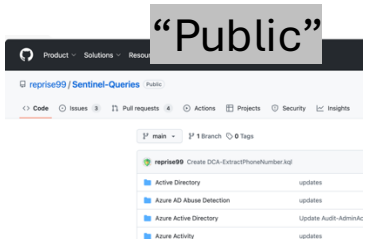
Detection KB

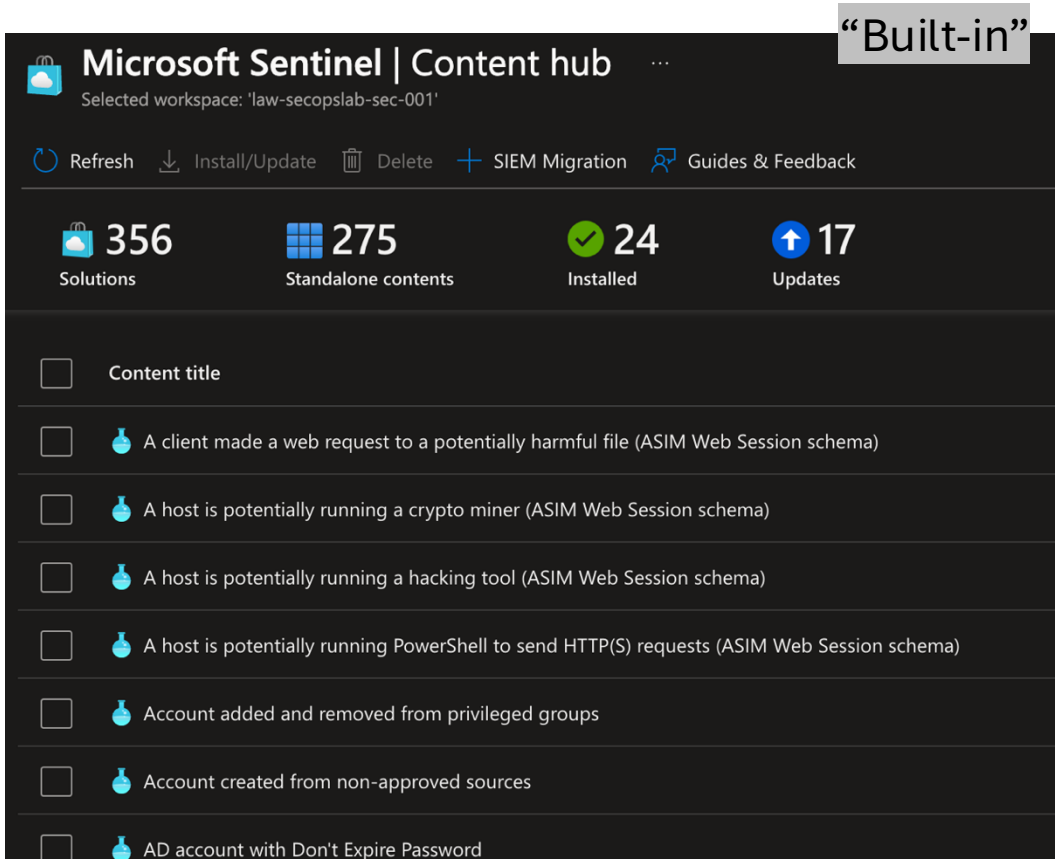


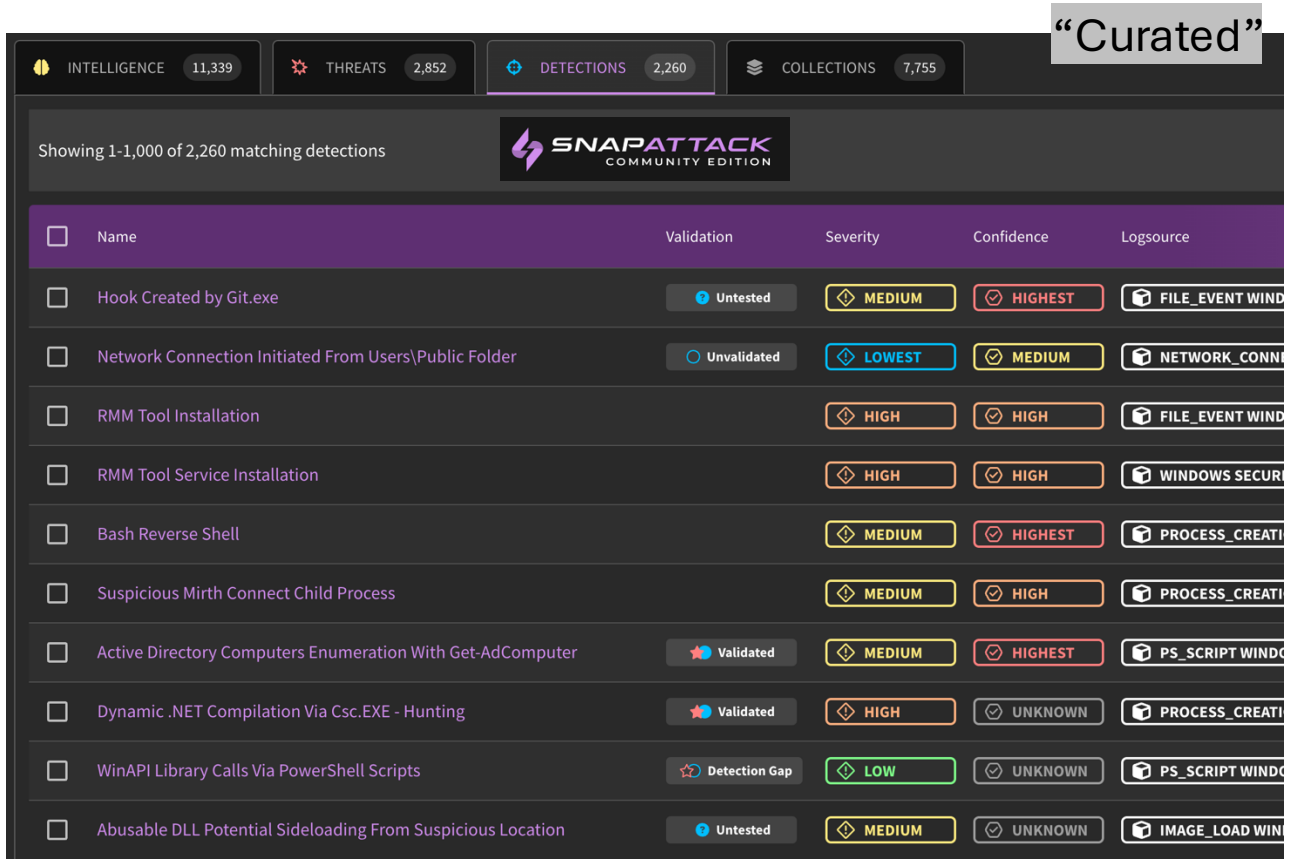
IAM-001: Break-Glass account usage
IAM-005: Tier 0 account login to non-T0 host
IAM-024: Entra ID user list bulk download
APP-011: Dynamics 365 audit log deletion
AWS-012: S3 bucket exposed via ACL
AZ-003: Azure Resource Lock Deleted

mikko@koivusec.fi

Using detections from external sources

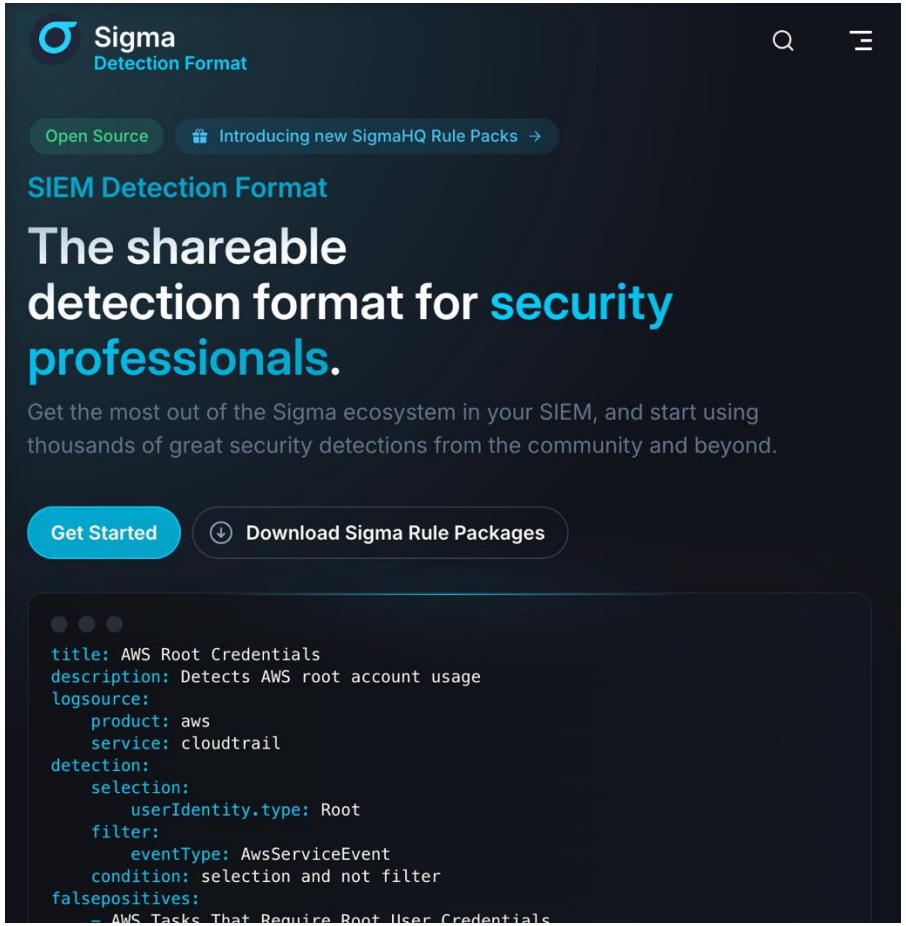


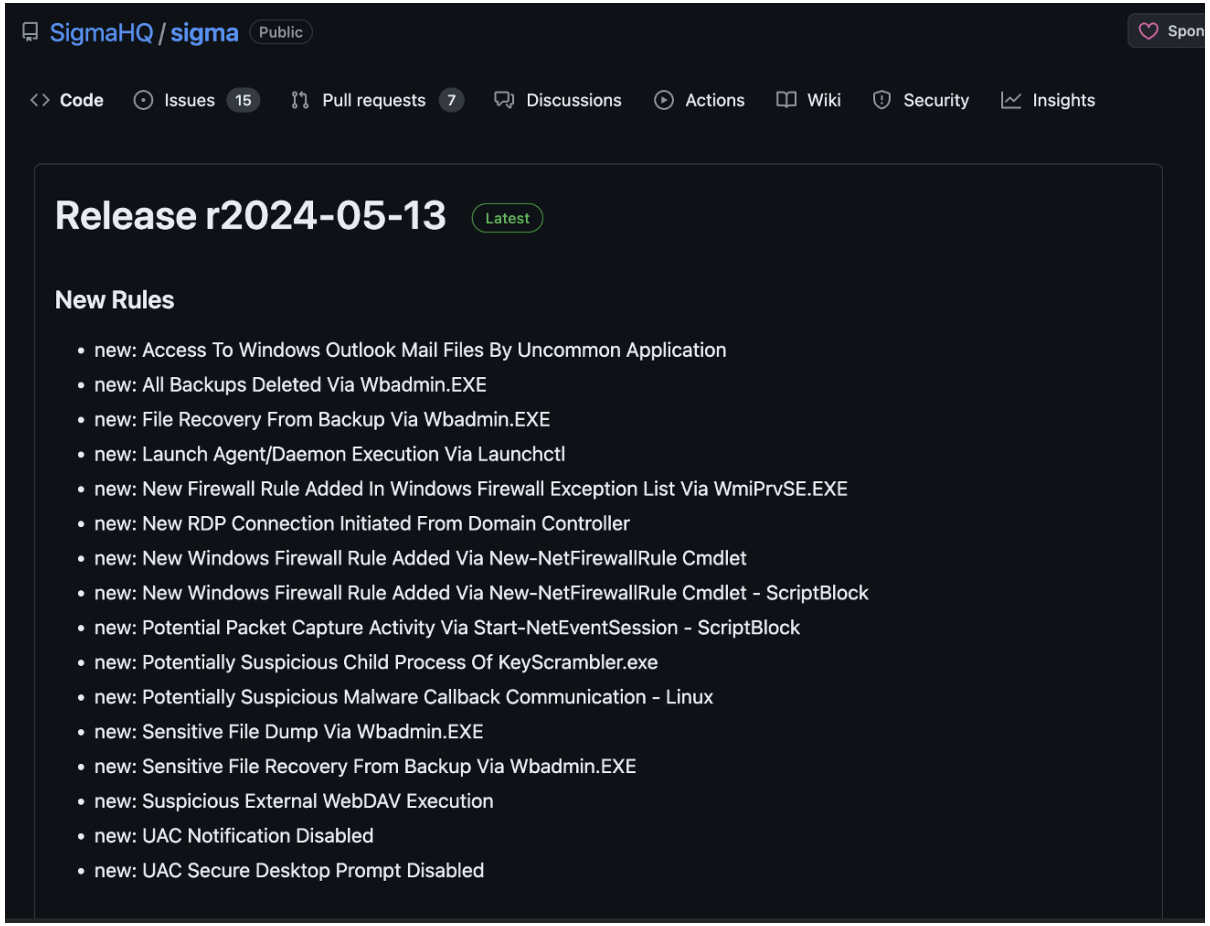




mikko@koivusec.fi

Sigma



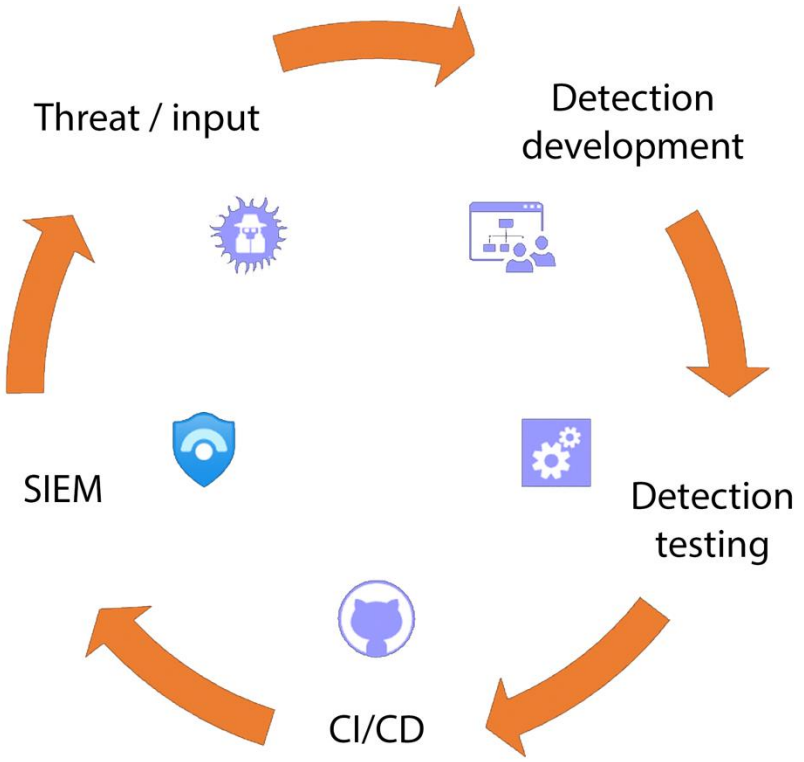


Importing Sigma Rules to Azure Sentinel | Microsoft Community Hub

mikko@koivusec.fi

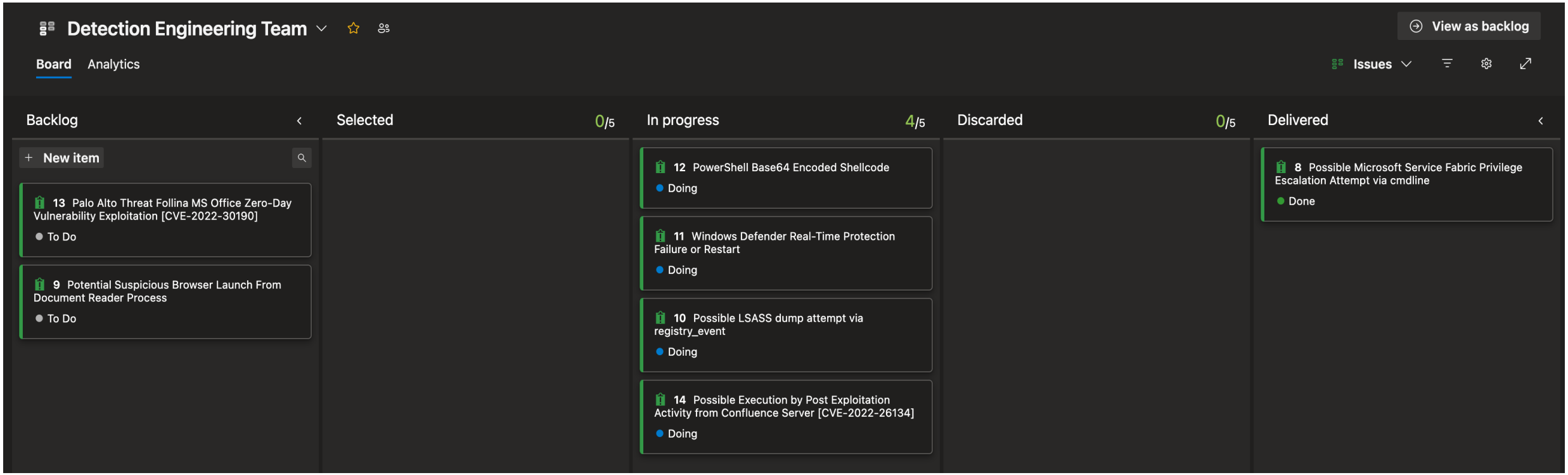
Process & Workflow

- Build a repeatable process for identifying, developing, testing and deploying detections.
- Technical side is fun, but this is how you succeed.



mikko@koivusec.fi

Development board example



mikko@koivusec.fi

Wrapping it up

More detections != better SOC

(alert fatique)

Better detections == better SOC

(high fidelity, actionable alerts)

mikko@koivusec.fi

Kiitos!

```
+=====================================+
| |         _)                        |
| | /  _ \  | \ \ / |  | (_-<  -_)  _||
|_\_\ \___/ _|  \_/ \_,_| ___/ \___| \__||
+=====================================+
```